AIT Merchandise System
Live-demo guide para sa panel

Exact na ipapagawa, makikitang result, tanong, at improvement. Batay ito sa submitted prototype at naunang local review. Review date: 02 October 2026.

Bago magsimula: Sabihin, "Gamit tayo ng dummy account at dummy requests para walang totoong records na maapektuhan." Unahin ang demos 1-3; madaling makita kahit walang coding knowledge.

1. Refresh status pero binabago ang status

1. Mag-register at mag-login gamit ang dummy account.
2. Mag-submit ng isang valid merchandise request.
3. Isulat o kopyahin ang Request ID.
4. Mag-logout.
5. Sa **Track Request**, ilagay ang kinopyang ID.
6. Pindutin ang **Track request**. Dapat **Submitted** muna.
7. Pindutin ang **Refresh status**. Tingnan kung naging **Processing**.
8. Pindutin ulit hanggang maging **Ready for Pickup**.
9. I-reload ang page at i-track ulit ang ID para makita kung naka-save ang pagbabago.

Ang butas: Requester o logged-out visitor mismo ang nakakapagpausad ng fulfillment status. Walang staff na nag-confirm na na-process o naihanda ang item.

"Wala namang staff na naghanda ng merchandise. Bakit naging Ready for Pickup dahil lang pinindot ko ang Refresh?"

Dapat improvement: Refresh ay babasa lang ng latest status. Kung simulation lang, dapat **Simulate next status - demo only** ang button. Sa actual service, authorized staff lang ang magpapalit ng status.

Evidence: Logged-out advance to Processing was confirmed sa earlier local test. Further stages and the final disabled button follow the code. Source: main.js lines 72-79 and 797-804.

Validation at contact delivery

2. Uniform pero N/A ang size

1. Mag-login.
2. Sa Request Form, piliin ang **School Uniform**.
3. Piliin ang **N/A** sa Size.
4. Quantity: **1**.
5. Pindutin ang **Submit request**.
6. Tingnan kung may successful confirmation at Request ID.

Ang butas: Kumpleto ang fields, pero hindi meaningful ang request. Paano ihahanda ang uniform kung walang garment size?

"Valid ba itong uniform request kahit N/A ang size? Ano ang ibibigay ng staff?"

Dapat improvement: School Uniform / PE Uniform: XS hanggang XXL. ID & Laces: N/A kung walang size requirement. Size choices dapat nakadepende sa item.

Isa pang ipatry: gumawa ng request na quantity ay **1000000**. Tinatanggap ito sa reviewed prototype. Itanong: "May agreed maximum ba per request? Kung wala, paano ninyo hahawakan ang ganitong quantity?" Hindi automatic na mali ang walang maximum; kailangan ng reasonable campus policy.

Evidence: Uniform/N/A/1000000 was accepted through the ordinary UI sa earlier test. Source: index.html lines 211-224; main.js lines 663-678.

3. Contact: Message sent pero saan napunta?

1. Pumunta sa **Contact**.
2. Ilagay ang dummy name, email, at message.
3. I-submit. Makikita ang **Message sent...**
4. Sabihin: **Pakita ngayon kung saan ito natanggap ng campus store team.**

Technical confirmation: bago mag-submit, pindutin ang **F12** -> **Network** -> **Fetch/XHR**. I-clear ang list, saka i-submit ang form. Tingnan kung may request na nagpapadala ng message. Sa tested submission, walang delivery request at walang message-storage operation.

"Bakit Message sent ang confirmation kung walang recipient o inbox na tumanggap?"

Dapat improvement: Kung prototype lang: **Demo only: hindi ipinadala ang message.** Kung actual feature, working intake at success confirmation pagkatapos talagang matanggap.

Evidence: Confirmed client-only success text. Source: main.js lines 817-824. Walang store o external recipient na kinontak sa testing.

Unsafe display ng user name

4. Pangalan na nagiging HTML

Simpleng demo ito ng unsafe display. Hindi kailangang gumamit ng harmful script.

1. Gumawa ng bagong dummy account.
2. Sa **Full Name**, ilagay nang eksakto: `<b>TEST</b>`
3. Gumamit ng bagong dummy Student/Staff ID at username.
4. Kumpletuhin ang registration at mag-login.
5. Tingnan ang **Hi, ...** greeting sa header.

Ang titingnan: Kung naging formatted na **TEST** at nawala ang literal na <b> tags, ini-interpret ang pangalan bilang HTML, hindi bilang ordinaryong text.

Ang butas: Hindi dapat nagiging page markup ang personal-data field. Unsafe HTML rendering can also allow browser script execution, depende sa input.

"Bakit puwedeng maging HTML ang Full Name? Paano kung mas dangerous na markup ang inilagay?"

Dapat improvement: Ipakita ang pangalan bilang plain text. Hindi sapat na required ang field; kailangan ding safe ang pag-display.

Evidence status: Ang simple `<b>TEST</b>` demonstration dito ay code-evidenced. Sa earlier local testing, ibang harmless name input ang ginamit at na-confirm ang execution ng in-memory script marker. Hindi kailangang ulitin ang script test sa presentation.

Source: main.js line 224 uses innerHTML for the greeting. Registration captures the name at lines 353 and 381, then stores it at line 151.

Importanteng interpretation: ang bold-name result ay nagpapakita ng HTML injection. Huwag itong ipresenta bilang proof na may data nang ninakaw o ibang device na na-compromise. Walang credential theft o remote spread na sinubukan sa review.

Local-storage limitations

5. Password ay mababasa sa browser

Fresh demo browser na dummy accounts lang ang laman. Huwag ipakita ang totoong passwords o existing personal records sa projector.

1. Mag-register ng dummy account na may dummy password.
2. Pindutin ang **F12**.
3. Pumunta sa **Application** tab.
4. Buksan ang **Local Storage**, tapos piliin ang address ng system.
5. Hanapin ang `ait_users`.
6. Tingnan ang dummy account record at ang `password` field.

Ang makikita: Nakasulat ang dummy password bilang readable text.

"Kung shared computer ito, paano ninyo mapoprotektahan ang account information na naiwan sa browser?"

Dapat improvement: Dummy-only prototype muna. Bago real deployment, trusted authentication at protected password storage.

Fair point: Inaamin na sa proposal na prototype authentication ito. Ito ay deployment limitation, hindi kailangang ipresenta na itinago nilang security feature. Plaintext dummy password was confirmed; source: main.js lines 156-158.

6. Request hindi makikita sa ibang browser

1. Sa normal browser, gumawa ng dummy request.
2. Kopyahin ang Request ID.
3. Buksan ang parehong system sa **Incognito/InPrivate** o ibang browser.
4. I-track ang ID doon.

Ang makikita: Hindi mahahanap ang request dahil nasa unang browser lang ang records. Gumamit ng parehong site/address para hindi ibang system ang maikumpara.

"Kung sa sariling laptop nagsubmit ang student, paano makikita ng campus store staff ang request sa computer nila?"

Dapat improvement: Para sa actual service: shared storage at staff request queue.

Fair point: Disclosed na local-only ang prototype. Ipinapakita nito kung bakit hindi pa actual online request service ang demo. A separate fresh browser context was tested and could not find the first context's request. Proposal page 7; main.js lines 38-55.

Ano pa ang dapat meron?

Ihiwalay ang **dapat ayusin ngayon** sa **kailangan bago actual gamitin** para fair ang evaluation. Merchandise request system ang basehan, hindi buong school-management platform.

Ayusin sa current prototype

Dapat ayusin	Bakit
Read-only Refresh at malinaw na simulator label	Hindi dapat mapagkamalang actual fulfillment ang button clicks.
Product-specific size validation	Para meaningful at prepareable ang request.
Defined quantity rules	Para malinaw kung ano ang acceptable request.
Safe display ng names at records	Para hindi maging executable HTML ang user input.
Honest contact confirmation	Para hindi umasa sa message na hindi naman ipinadala.
Consistent save/error handling	Hindi dapat success sa screen pero hindi pala naka-save.
Reliable unique Request IDs	Para hindi maging ambiguous ang tracking.
Magkakatugmang proposal at documentation	Merchandise ang actual source, pero may ibang school-management claims sa documentation.

Bago gamitin sa totoong campus operations

Staff dashboard: makita at ma-review ang requests. **Trusted staff permissions:** hindi sapat ang self-selected Staff account. **Shared records:** parehong request sa student at staff devices.

Request handling: accept, reject, cancel, at reason kung unavailable. **Availability policy:** request lang ba o guaranteed stock/reservation? **Pickup completion:** hiwalay ang Ready for Pickup at Collected.

Status history: sino ang nag-update, kailan, at bakit. **Recovery at personal-data handling:** backup, retention, at correction process.

Hindi kailangang hingin: grades, attendance, enrollment, online payment, delivery, o mobile app. Excluded ang mga iyon sa focused System Proposal, page 7. Ang staff/backend capabilities ay future work under that proposal, hindi missing prototype requirements.

"Paano makakarating ang request mula sa student papunta sa authorized staff, at paano mapapatunayang totoong naihanda at na-release ang merchandise?"